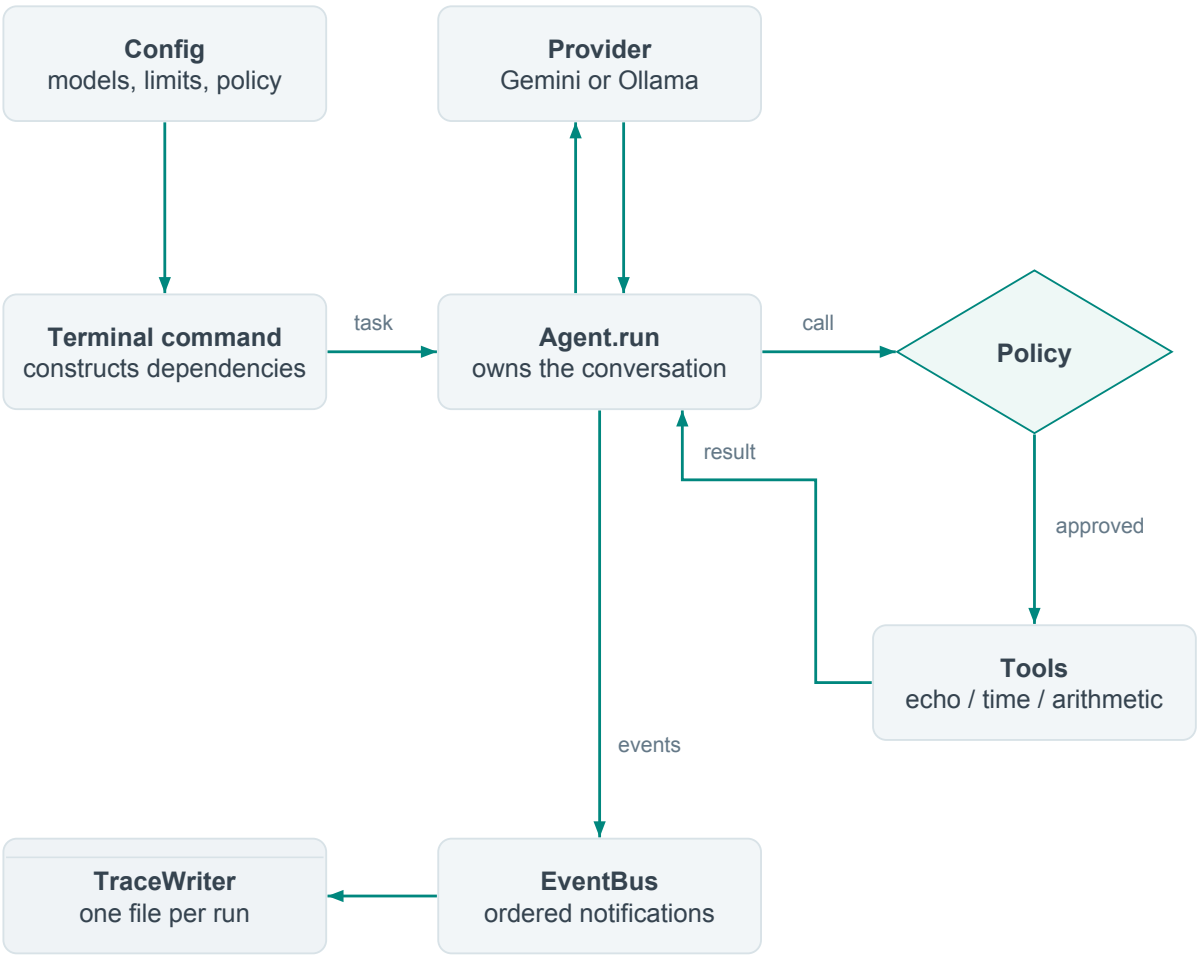
ENGINEERING NOTES / 01

Foundation

A small agent. Explicit control.



What we built and why

An agent turns model suggestions into controlled actions.
Two providers, three demo tools, approval rules, and run records.
A testable foundation for more powerful capabilities later.

`src/pilot/agent/loop.py: Agent.run`
`src/pilot/cli.py: create_app`

START HERE

Your reading map

Overview: the whole foundation	01
A conversation with a stopping rule	03
One interface, independent instances	04
A request is not permission	05
Controlled waiting, repeatable evidence	06
Settings in, evidence out	07
Follow one request	08
Choices and their costs	09
What can fail?	10
Interview corner	11
Try it yourself + quick quiz	12
Glossary at a glance	13
Next phase + answers	14

Reading route Scan diagrams, read cards, then explain the interview answers aloud.

Evidence boundary The walkthrough uses an existing offline test. It demonstrates control flow, not live-provider acceptance.

CONCEPTS / MODEL + CONTROL

A conversation with a stopping rule

01

Stateless API

What An LLM is a language model. Its API, a calling contract, receives context again on each request.

Why Roles label system instructions, user tasks, assistant replies, and tool results.

`src/pilot/providers/base.py: Message`

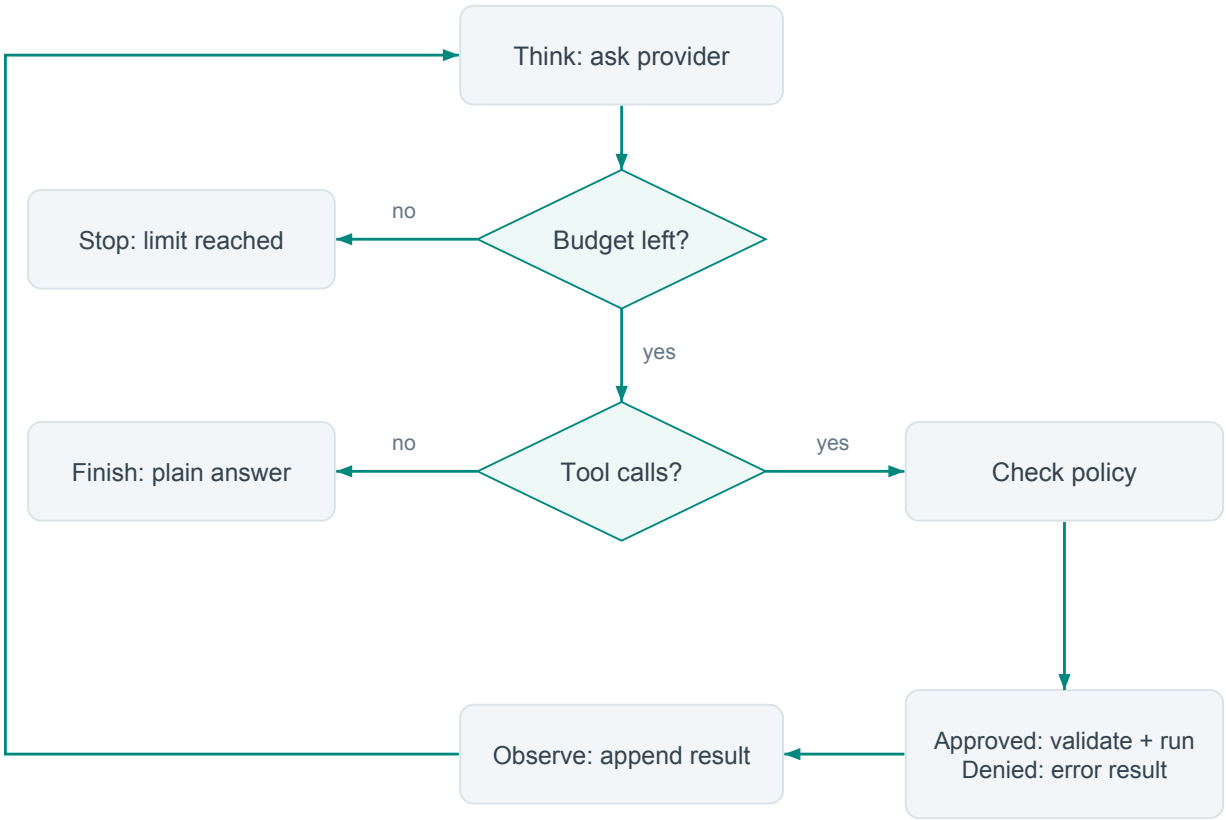
02

Loop + limits

What The agent repeats think, act, observe. A plain answer finishes.

Why Step limits bound provider calls; token limits bound reported text units.

`src/pilot/agent/loop.py: Agent.run`



A response can overshoot the token budget. At exhaustion, none of its tool calls executes.

Step exhaustion is checked before the next provider call. Internal HTTP retries do not add agent steps.

CONCEPTS / BOUNDARIES

One interface, independent instances

03

Provider abstraction

What An interface specifies behavior. An adapter translates a vendor format into shared messages.

Why The loop calls a Python Protocol, an interface contract, instead of vendor fields.

`src/pilot/providers/base.py: LLMProvider`

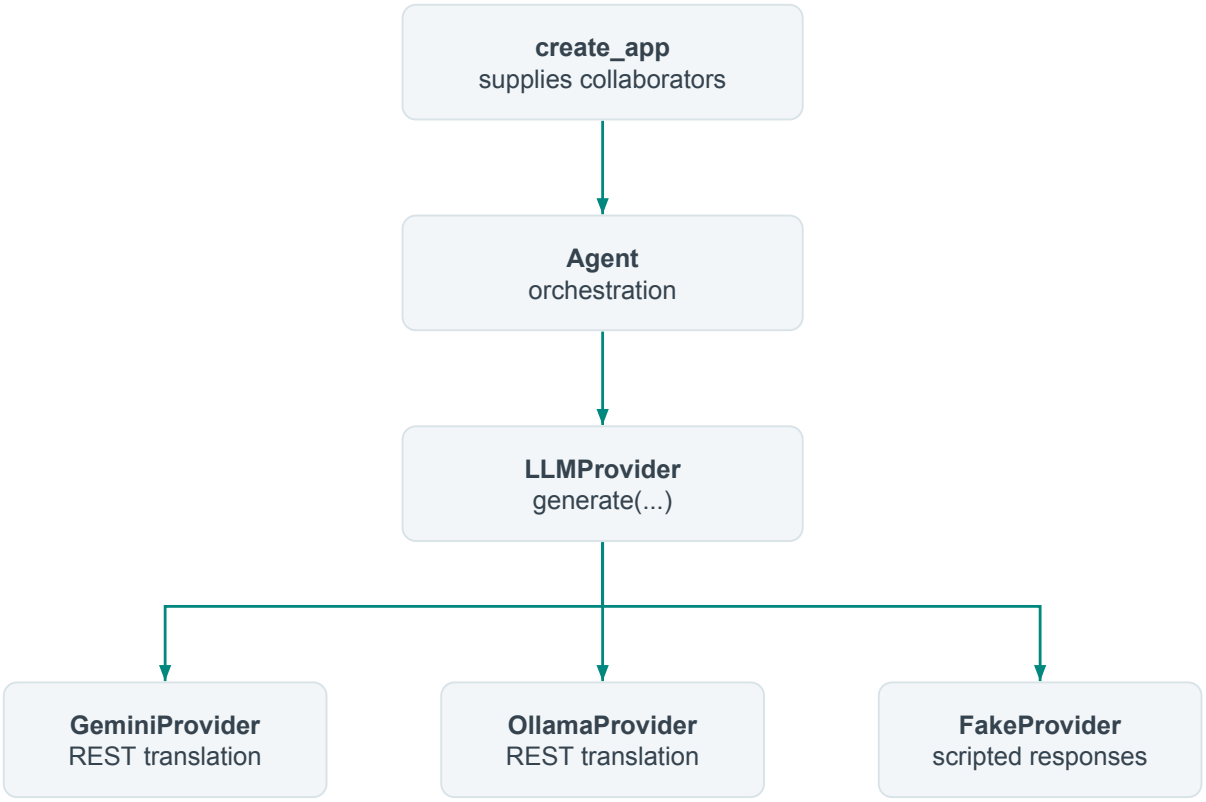
04

Dependency injection

What Dependencies are required collaborators. Injection supplies them explicitly.

Why Each agent can receive separate tools, provider, policy, bus, and prompt. Run messages stay local.

`src/pilot/agent/loop.py: Agent.__init__`



Analogy One socket accepts different adapters; separate desks keep separate case folders.

REST uses direct HTTP web requests.

`src/pilot/providers/__init__.py: create_provider`

CONCEPTS / ACTIONS

A request is not permission

05

Tools + schemas

What A tool call names an action and arguments. JSON is structured text; JSON Schema describes allowed shapes.

Why Pydantic, a validation library, checks arguments. Errors return to the model instead of crashing.

`src/pilot/tools/registry.py: ToolRegistry.execute`

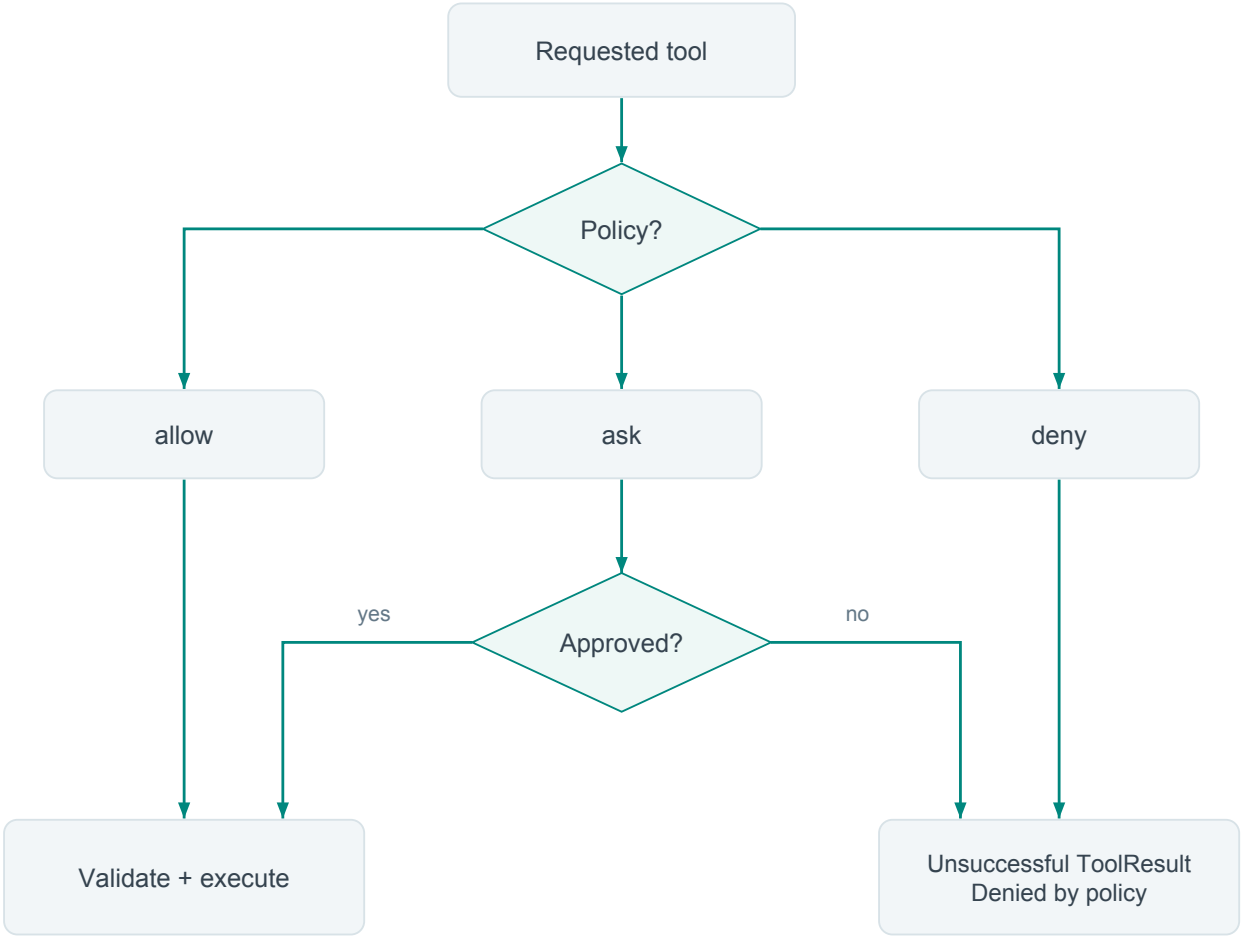
06

Policy + approval

What Policy resolves allow, ask, or deny. Human-in-the-loop means a person decides at approval.

Why Ask by default prevents silent execution. Least privilege grants only necessary access.

`src/pilot/permissions.py: PolicyEngine.decide`



Risk labels describe tools; they do not enforce another rule. End-of-input denies an approval request.

`src/pilot/tools/base.py: Tool.spec, ToolArgs`

CONCEPTS / RELIABILITY

Controlled waiting, repeatable evidence

07

Retries

What Retries repeat failed requests. Exponential backoff doubles waits; jitter randomizes them.

Why Recover from 429 request quotas, 5xx server errors, or timeouts: expired waits. Attempts are bounded.

`src/pilot/providers/retry.py: post_json`

08

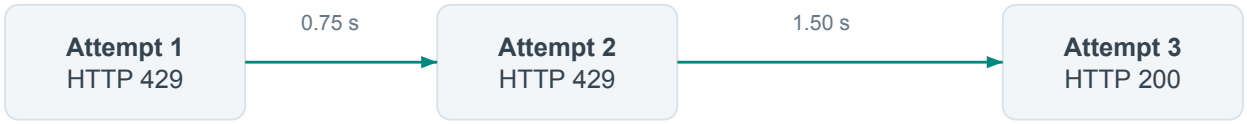
Fakes

What A fake is a controlled replacement returning scripted responses.

Why Repeatable tests force failures without network. MockTransport substitutes HTTP responses to test adapters.

`src/pilot/providers/fake.py: FakeProvider`

RETRY TIMELINE / A DETERMINISTIC TEST EXAMPLE



Analogy Wait before calling a busy office again.

Outcome	Rule
Retry	429 / 5xx / timeout
Fail immediately	Permanent HTTP errors / connection failures
Stop	Attempts exhausted / Retry-After exceeds wait cap

`tests/test_providers.py: test_retry_status_and_jitter`

Base delay 0.5 s; fixed jitter 0.5. Request durations are not shown. Retry-After supplies the server's requested wait.

CONCEPTS / VISIBILITY

Settings in, evidence out

09

Config + secrets

What Configuration supplies settings. Secrets, such as API keys, require restricted disclosure.

Why Environment overrides YAML, a readable settings format. SecretStr masks display; redaction masks known keys.

`src/pilot/config.py: Config, load_config`

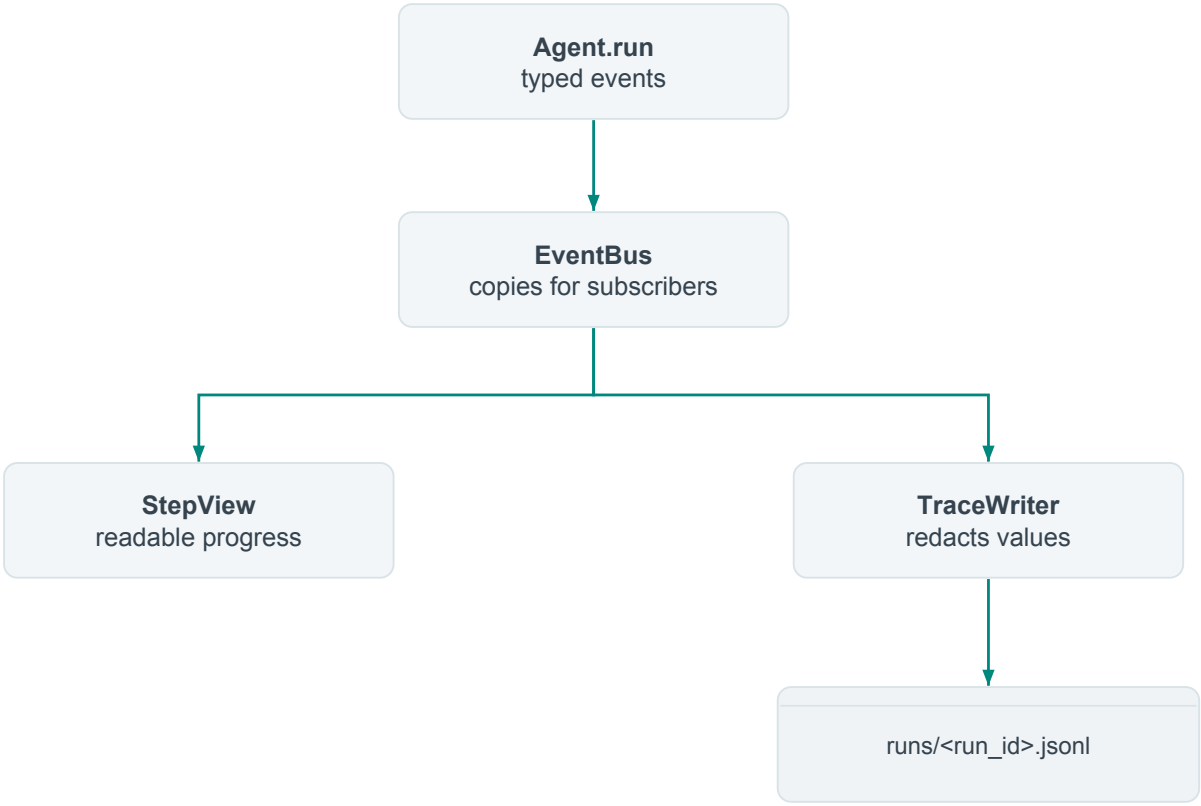
10

Events + traces

What Events record occurrences. An event bus delivers them to subscribers: registered listeners.

Why A trace records one run. JSONL stores one JSON object per line.

`src/pilot/events.py: EventBus, TraceWriter`



Settings precedence
Provider flag > environment > .env > YAML > defaults.

Subscribers run immediately. Trace-write errors stop subsequent actions. Masking a secret is not encryption.

WALKTHROUGH / AN EXISTING OFFLINE SCENARIO

Follow one request

`tests/test_cli.py: test_cli_with_real_adapter_and_mock_http`

Real Ollama adapter; substituted HTTP responses; two approved prompts.

01
run_started + llm_requested
step=1; messages: system + user
task: What is 17*23 and what time is it?

02
llm_responded
tool_calls: calculator {"expression":"17*23"}, get_time {}
usage: input_tokens=10, output_tokens=5

03
tool_requested > policy_decided > tool_finished
calculator: policy="ask", allowed=true
result: {"ok":true,"output":"391"}

04
tool_requested > policy_decided > tool_finished
get_time: policy="ask", allowed=true
result.output: local ISO date/time with offset

05
llm_requested
step=2; assistant calls + two tool messages
content: serialized ToolResult; tool_call_id links each result

06
llm_responded + run_finished
final_text="391, now"; status="completed"; steps=2
usage: input_tokens=25, output_tokens=8 (total 33)

Shared event fields type / timestamp / run_id / agent_id / parent_id
Here: agent_id="pilot", parent_id=null. IDs and timestamps vary.

`src/pilot/events.py: BaseEvent`

DESIGN

Choices and their costs

SDK means a vendor client library. Sequential means one call at a time.

Decision	Alternative	Why we chose it	Cost
Direct HTTP	Vendor SDK	Visible translation	Maintain formats
Sequential tools	Parallel tools	Predictable approval order	No overlap
Ask by default	Allow by default	Explicit human consent	Prompt fatigue
Validate arguments	Trust model output	Reject malformed calls	Another exchange
Reported usage	Estimate first	Provider-supplied counts	Can overshoot
Synchronous bus	Separate delivery	Simple event ordering	Subscribers can stall

Simplicity reduces moving parts. It does not remove the cost in the last column.

`docs/DECISIONS.md: design log (packaging note predates current setup)`

`src/pilot/agent/loop.py: Agent.run`

`src/pilot/events.py: EventBus.emit`

OPERATIONS

What can fail?

Failure	Our defence / remaining gap
Endless tool loop	Step and reported-token limits. `src/pilot/agent/loop.py: Agent.run`
Malformed request	Unknown names and invalid arguments become error results. `src/pilot/tools/registry.py: ToolRegistry.execute`
Rate-limit storm	Bounded waits. No shared multi-agent rate controller. `src/pilot/providers/retry.py: post_json`
Unapproved action	Policy check precedes execution. `src/pilot/permissions.py: PolicyEngine.decide`
Prompt injection	Untrusted text redirects the model: prompt advice only; no robust isolation. `src/pilot/agent/prompts.py: DEFAULT_SYSTEM_PROMPT`
Secret leakage	Known keys masked. Arbitrary personal data is not scrubbed. `src/pilot/events.py: Redactor`

A failed trace write can prevent the final event from being recorded. Closing a file does not guarantee recovery after a machine crash.

INTERVIEW CORNER

Explain the boundary

What makes this an agent?

It repeatedly chooses tools and observes results. Python controls whether requested actions execute.

Why hide provider formats?

One interface keeps orchestration independent. Adapters preserve vendor-specific formats and context.

Why inject dependencies?

Each instance receives its collaborators. Tests replace providers without changing the loop.

Does JSON Schema make a tool safe?

It describes input shape. Permission checks and tool-specific restrictions remain necessary.

Why script model responses in tests?

A fixed script makes failures repeatable. It cannot prove live compatibility or model judgment.

Revisit Agent.run, LLMProvider, ToolArgs, and FakeProvider in the concept references.

PRACTICE

Try it, then explain it

Run `export UV_OFFLINE=true`. Commands inspect settings or run existing offline tests.

- [ ] **Inspect settings**

```
uv run pilot config show
```

Observe: keys masked. Concept: secret handling.

- [ ] **Change permission**

```
PILOT_POLICY__TOOLS__CALCULATOR=deny uv run pilot tools
```

Observe: calculator policy changes. Concept: least privilege.

- [ ] **Lower the limit**

```
PILOT_LIMITS__MAX_STEPS=1 uv run pilot config show
```

Observe: effective limit is 1. Concept: configuration precedence.

- [ ] **Inspect errors**

```
uv run pytest -k tool_errors_return_to_model
```

Observe: three cases pass. Concept: error feedback.

Quick quiz / answers on the last page

1. Why resend earlier messages?
2. Who executes a tool call?
3. What replaces invalid arguments?
4. Does high risk automatically deny?
5. Can token usage overshoot?
6. Why add retry jitter?
7. What does a fake prove?
8. Why can tracing stop execution?

`tests/test_agent.py: test_tool_errors_return_to_model`

REFERENCE

Glossary at a glance

Adapter Format translator.

Agent Action coordinator.

API Calling contract.

Backoff Growing waits.

Configuration Operating settings.

Dependency Required collaborator.

Dependency injection Explicit collaborators.

Event Recorded occurrence.

Event bus Subscriber dispatcher.

Fake Controlled replacement.

Global state Shared mutable data.

Guardrail Execution boundary.

HTTP Web request protocol.

Human-in-the-loop Person decides.

Interface Required behavior.

Jitter Random wait variation.

JSON Structured text.

JSON Schema Data-shape rules.

JSONL One JSON per line.

Least privilege Minimum access.

LLM Language generator.

Message role Source/purpose label.

MockTransport Substituted HTTP responses.

Policy Allow/ask/deny rule.

Protocol Python interface contract.

Provider Model service.

Pydantic Validation library.

Rate limit Request quota.

Redaction Secret masking.

REST HTTP API style.

Retry-After Server-requested wait.

Schema Expected data shape.

SDK Vendor client library.

Secret Sensitive value.

SecretStr Masked Pydantic string.

Serialization Values to text.

Stateless No automatic memory.

Subscriber Event listener.

Synchronous Calls in sequence.

Timeout Waiting deadline.

Token Model counting unit.

Tool call Proposed named action.

Trace Run history.

UTC Reference time.

Validation Input checks.

YAML Readable settings.

Definitions describe each term's role, rather than individual code lines.

LOOK AHEAD

The next boundary

Next phase / scope to be defined

Add one narrowly permissioned capability.
Define accepted inputs and external effects first.
Reuse these interfaces; test failures and denials.

Answers / quick quiz

1. Each stateless request needs its context explicitly.

2. Python, after policy and validation.

3. An unsuccessful ToolResult, returned to the model.

4. No. Configured policy determines access.

5. Yes. Reported usage arrives after generation.

6. To spread requests rather than synchronize bursts.

7. Repeatable local behavior, not live compatibility.

8. Subscriber errors propagate before the next action.

No planner, child agents, laptop tools, or saved conversation memory exist in this phase.